

Sri Lanka Institute of Information Technology



Enterprise Standards for Information Security - IE3102

Risk Treatment Plan

IT23269484 – T. H. Ranasinghe

1. Introduction

The Risk Treatment Plan (RTP) is a fundamental document within an Information Security Management System (ISMS). Under Clause 6.1.3 (a–c) of ISO/IEC 27001:2022, organizations must establish and implement a plan that defines how each identified information-security risk will be treated.

The RTP bridges the gap between risk assessment and control implementation, transforming identified risks into actionable steps supported by specific Annex A controls. It documents the strategy for reducing, transferring, avoiding, or accepting risks and provides verifiable evidence of compliance during internal and external audits.

The purpose of this document is to outline the framework, process, and structure for developing and maintaining an effective RTP aligned with the 2022 edition of the ISO 27001 standard.

2. Purpose and Objectives

The RTP serves as the organization’s blueprint for managing information security risks. Its objectives are to:

- Provide a systematic approach for selecting appropriate treatment actions.
- Ensure accountability by assigning ownership of every mitigation task.
- Demonstrate alignment with Annex A controls and business risk appetite.
- Enable auditability and continual improvement through documentation and tracking.
- Support the Plan–Do–Check–Act (PDCA) cycle that underpins ISO 27001.

The RTP not only satisfies certification requirements but also strengthens decision-making by allowing management to visualize priorities, resource needs, and treatment progress in a single reference point.

3. Scope of the RTP

The RTP applies to all information assets, processes, and systems within the defined ISMS scope. It encompasses:

- Digital assets: servers, databases, applications, and cloud environments.
- Physical assets: facilities, storage media, and network hardware.
- Human assets: employees, contractors, and third-party service providers.
- Supporting processes: finance, HR, procurement, and IT operations.

Each risk recorded in the Risk Register is reviewed here, evaluated for treatment options, and mapped to corresponding ISO 27001 Annex A controls.

4. Relationship with Other ISMS Documents

Document	Purpose	Relationship to RTP
Risk Assessment Report	Identifies threats, vulnerabilities, and risk levels.	Feeds inputs (risk IDs, ratings) into the RTP.
Statement of Applicability (SoA)	Lists all Annex A controls and justification for inclusion/exclusion.	The RTP references controls selected in the SoA.
Asset Registry	Records ownership, classification, and value of information assets.	Risks are linked to corresponding assets in the registry.
Management Review Records	Track performance, corrective actions, and continual improvement.	Management decisions may adjust priorities or treatment actions.

This integration guarantees traceability from risk identification → control selection → implementation and monitoring.

5. Risk Treatment Process

The process of establishing a Risk Treatment Plan follows the PDCA approach and consists of six steps:

Step 1 – Identify Risks

Risks are imported from the approved Risk Assessment. Each must have a unique identifier (e.g., R001) and a concise description.

Step 2 – Evaluate Risk Severity

Determine likelihood and impact values to confirm whether the risk level is Low, Medium, or High. Only validated, significant risks are prioritized for treatment.

Step 3 – Select Treatment Option

For each risk, management decides one of four approaches:

Treatment Option	Description	Example
Avoid	Discontinue the activity causing the risk.	Stop storing PII on portable devices.
Mitigate	Apply controls to reduce probability or impact.	Implement MFA to reduce unauthorized access.
Transfer	Shift part of the risk to a third party.	Purchase cyber-insurance or outsource hosting.
Accept	Formally acknowledge low-level risk.	Retain minimal residual risk within tolerance.

Step 4 – Select Annex A Controls

Each chosen treatment must cite at least one Annex A control (A.5 – A.10) that provides mitigation evidence.

Example: “Implement A.5.30 Access Control Policy to limit system log-in attempts.”

Step 5 – Assign Responsibilities and Resources

Every treatment action is assigned to an owner (e.g., ISMS Manager, IT Administrator, HR Lead) with a defined target completion date and necessary resources.

Step 6 – Monitor, Review, and Update

Progress is tracked through audit findings, KPIs, and management reviews. The RTP must be reviewed at least quarterly or after significant changes (e.g., new technology, mergers, or incidents).

6. Standard RTP Template

Field	Description
Risk ID	Unique identifier (e.g., R001).
Risk Description	Short summary of the risk scenario.
Risk Level	Low / Medium / High based on assessment.
Treatment Option	Avoid / Mitigate / Transfer / Accept.
Relevant Annex A Control	Control ID (e.g., A.5.30 Access Control).
Action Required	Concrete mitigation steps.
Responsible Person	Designated owner of the action.
Target Date	Planned completion date.
Residual Risk Level	Expected level after treatment.
Status	Open / In Progress / Closed.

7. Example Excerpt from an RTP

Risk ID	Description	Level	Treatment	Annex A Control	Action	Owner	Target Date	Residual Risk	Status
R001	Unauthorized access to employee records	High	Mitigate	A.5.30 Access Control Policy	Implement MFA and review access logs quarterly.	IT Manager	1-Mar-26	Medium	Open
R002	Loss of financial data due to hardware failure	Medium	Transfer	A.5.29 Backup	Deploy off-site cloud backup with daily replication.	Operations Lead	15-Feb-26	Low	Closed
R003	Phishing attacks targeting staff	High	Mitigate	A.6.3 Awareness Training	Conduct quarterly awareness sessions and simulated phishing	HR Manager	10-Apr-26	Medium	In Progress

8. Roles and Responsibilities

Role	Responsibility
Top Management	Approves RTP, allocates resources, and accepts residual risks.
ISMS Manager	Maintains RTP and ensures alignment with other ISMS documents.
Risk Owners	Implement actions and report progress.
Internal Auditors	Verify completion and effectiveness of risk-treatment activities.
All Employees	Follow implemented controls and report incidents promptly.

This clear ownership model ensures that risk treatment remains measurable and enforceable.

9. Review and Maintenance

RTP is a living document. It should be updated whenever:

- New risks emerge due to technological or organizational change.
- Audit results reveal control weaknesses.
- Incidents occur that expose unaddressed vulnerabilities.
- Management revises risk appetite or strategic priorities.

Version control practices (e.g., 1.0, 1.1) must be applied, with each revision approved by the ISMS Manager. Historical versions are retained for audit traceability.

10. Integration with PDCA Cycle

Phase	RTP Contribution
Plan	Identify and analyze risks; select appropriate controls.
Do	Implement chosen risk-treatment actions.
Check	Evaluate control performance via audits and KPI reviews.
Act	Revise the RTP and update risk ratings for continual improvement.

Embedding RTP within PDCA ensures continuous enhancement of the organization's security posture.

11. Common Challenges and Recommended Solutions

Challenge	Description	Solution
Incomplete linkage between risk register and RTP	Risks lack corresponding actions or controls.	Introduce automated mapping between registers and the RTP.
Stale RTP updates	The plan is not refreshed after changes.	Schedule quarterly reviews with management approval.

Lack of accountability	No assigned risk owners.	Maintain a RACI matrix and ensure signatures for accountability.
Over-documentation	Excessive narrative slows progress.	Use concise tabular format and digital dashboards.
Poor evidence collection	No proof of control implementation.	Require artifacts (logs, policies, screenshots) for each “Closed” risk.

12. Benefits of an Effective RTP

An effective Risk Treatment Plan contributes to both security resilience and business efficiency:

- Demonstrates due diligence and governance maturity.
- Reduces the probability and impact of security incidents.
- Simplifies ISO 27001 audits by providing direct evidence of compliance.
- Builds stakeholder confidence through visible risk management.
- Enables data-driven prioritization of resources.
- Supports regulatory compliance (e.g., GDPR, PDPA).

13. Conclusion

The Risk Treatment Plan (RTP) is a cornerstone of ISO/IEC 27001:2022 implementation. It operates the organization’s risk-management strategy by defining who does what, when, and how for every identified security risk.

By maintaining a current and auditable RTP linked to the Risk Register, SoA, and Asset Registry, an organization demonstrates that its ISMS is active, transparent, and continuously improving.

Ultimately, a well-structured RTP transforms risk management from theory into practice turning awareness into measurable action and compliance into lasting security assurance.

14. References

- Aleksandrov, Mark N. and Vasiliev, Victor A. and Aleksandrova, Svetlana V. (2021). Implementation of the Risk-based Approach Methodology in Information Security Management Systems. 2021 International Conference on Quality Management, Transport and Information Security, Information Technologies (IT&QM&IS), (pp. 137-139).
- Guo, Huaqun and Wei, Meng and Huang, Ping and Chekole, Eyasu Getahun. (2021). Enhance Enterprise Security through Implementing ISO/IEC 27001 Standard. 2021 IEEE International Conference on Service Operations and Logistics, and Informatics (SOLI).
- (Third edition 2022-10). ISO/IEC 27001:2022 - Information Security Management Standards, International Organization for Standardization. INTERNATIONAL STANDARD.
- Malatji, Masike. (2023). Management of enterprise cyber security: A review of ISO/IEC 27001:2022. 2023 International Conference On Cyber Management And Engineering (CyMaEn).